

ECOM EXPERTS

Ecom secadmin

Manual de usuario, tecnico y de desarrollo

ecom_secadmin 1.1.0 · 07/09/2026

Contenido

Pantallas del módulo

Lista blanca de IPs

Avisos por email

Eventos del log

Cookie de confianza

Fingerprint de sesión

Export CSV

Índice

Resumen rápido

1. Identificación

2. Responsabilidad funcional

3. Tablas

4. Configuración (Configuration::*)

5. Hooks registrados

6. Tabs creados

7. Endpoints públicos

8. Compatibilidad multi-versión

9. Conexión externa (Gmartos)

10. Mantenimiento

11. Seguridad

Estructura del módulo

Cómo extender

Añadir un nuevo evento de log

Añadir un proveedor de geolocalización

Añadir nueva configuración persistente

Hooks personalizados

Convenciones de código

Testing manual

Integración Gmartos

Auditoría rápida

Estoy fuera de España y no me deja entrar

Me he autobloqueado

He cambiado de IP (mi ISP me cambió la IP doméstica)

Ip-api.com es lento o me devuelve error

¿Compatible con 2FA?

¿Compatible con CDN / proxy inverso?

¿Puedo desactivar el geofencing y dejar sólo la whitelist?

¿Cuánto cuesta el módulo en consultas externas?

Requisitos

Pasos

Primer arranque

Cron de purga (opcional)

Desinstalación

Matriz de acceso

Capas de defensa para instalación de módulos

Geofencing

Cookie de confianza

Token de aprobación por email

Logs

Lo que el módulo NO hace (consciente)

Pantallas del módulo

El módulo crea cuatro pantallas en el back-office:

- **Configurar > Sec Admin > Configuración:** ajustes generales y lista blanca.
- **Configurar > Sec Admin > Registro de accesos:** log completo con filtros y export CSV.
- **Configurar > Sec Admin > IPs detectadas:** vista compacta de IPs vistas, con país, último evento y botón "+ Whitelist".
- **Configurar > Parámetros avanzados > Seguridad > Accesos autorizados / no autorizados** (en PS 8/9; en PS 1.7.8 y 8.1 está bajo Parámetros avanzados): pestañas Autorizados / No autorizados.

Lista blanca de IPs

Acepta:

- IPs sueltas: `83.45.12.7` , `2001:db8::1`
- Rangos CIDR: `83.45.0.0/16` , `2001:db8::/32`

Una IP en la whitelist:

- Bypassa el geofencing (puede entrar aunque no sea de España).
- Es la única que puede entrar a la zona de **gestión de módulos**.
- Sigue sometida al fingerprint y a la cookie de confianza.

Avisos por email

Se envían siempre al **dueño de la tienda** (PS_SHOP_EMAIL) y a los emails configurados en el módulo, deduplicados.

Tipos de aviso:

Asunto	Cuándo
Alguien intenta acceder a modulos instalados	Acceso a <code>AdminModules*</code> desde IP no whitelisted
Alguien intenta entrar en administracion de la tienda	Login desde IP no española y no whitelisted
Alguien intenta instalar un modulo	Hook de install dispara desde IP no whitelisted

Cada email incluye un **enlace de aprobación** firmado con HMAC y válido 24 horas. Al pulsarlo, la IP queda añadida a la lista blanca.

Eventos del log

Tipo	Significado
proceso	Una IP no whitelisted ha cargado la pantalla de login
login	Se han enviado credenciales
acceso	Sesión autenticada activa
block_module	Bloqueado el acceso a la zona de módulos
block_install	Bloqueada una instalación/desinstalación
block_geo	Bloqueado por estar fuera de España
block_fingerprint	Sesión cerrada porque cambió UA / Accept-Language
block_unknown	Bloqueo genérico (cookie inválida, etc.)

Cookie de confianza

Tras un login correcto, se emite una cookie firmada con HMAC, **HttpOnly**, **Secure** y **SameSite=Strict**, válida 7 días por defecto. Cuando expira el usuario debe volver a loguearse aunque su IP siga en la whitelist. Cambia la duración en Configuración.

Fingerprint de sesión

Al primer request autenticado se calcula `sha256(UserAgent + AcceptLanguage)` y se guarda en la cookie de PrestaShop. Si en cualquier request posterior el hash no coincide, la sesión se cierra y se loguea `block_fingerprint`. Esto detecta robo de cookie aunque el atacante venga desde una IP whitelisted.

Export CSV

Disponible en: - Registro de accesos - Accesos autorizados / no autorizados (por pestaña)

Los CSV usan delimitador `;` y BOM UTF-8 para abrir bien en Excel español.

Ecom Sec Admin — Documentación

Módulo de seguridad para el back-office de PrestaShop. Restringe el acceso por **IP (lista blanca)**, **país (geofencing España)**, **fingerprint de sesión** y endurece la **instalación de módulos**.

Compatible con **PrestaShop 1.7.8, 8.x y 9.x**.

Índice

Documento	Para quién	Contenido
INSTALL.md	Cliente / instalador	Instalación paso a paso, requisitos, primer arranque
USER_GUIDE.md	Administrador de la tienda	Cómo añadir IPs, ver logs, gestionar avisos
SECURITY.md	Cliente / auditor	Qué bloquea el módulo y por qué (modelo de seguridad)
FAQ.md	Cliente	Preguntas frecuentes y resolución de problemas
DEVELOPER.md	Desarrollador / integrador	Arquitectura, hooks, base de datos, extensión
CHANGELOG.txt	Todos	Historial de versiones

Resumen rápido

- **Lista blanca de IPs** (sueltas y rangos CIDR, IPv4 e IPv6).
- **Geofencing duro**: sólo IPs de España o whitelist pueden acceder.
- **Cookie de confianza** firmada (HMAC), 7 días por defecto.
- **Fingerprint de sesión** (UA + Accept-Language).
- **3 eventos auditados**: `proceso`, `login`, `acceso`, más bloqueos.
- **Defensa en 2 capas** para instalación de módulos: controlador + hook.
- **Aviso por mail** al dueño + emails configurados, con enlace tokenizado para autorizar la IP.
- **Purga automática** diaria + export CSV de los logs.

Documento Técnico — Ecom Sec Admin

1. Identificación

- **Nombre técnico:** `ecom_secadmin`
- **Clase principal:** `Ecom_Secadmin` (Global Namespace)
- **Versión:** 1.0.0
- **Compatibilidad:** PrestaShop 1.7.8, 8.x, 9.x · PHP 7.1+
- **Licencia:** AFL-3.0
- **Autor:** Ecom Experts (ecomyseo@gmail.com)

2. Responsabilidad funcional

Securización del back-office de PrestaShop con cuatro capas independientes:

1. **Lista blanca de IPs** (sueitas y CIDR, IPv4/IPv6).
2. **Geofencing duro** España (con whitelist como único bypass).
3. **Cookie de confianza firmada con HMAC** (vida 7 días).
4. **Fingerprint de sesión** (UA + Accept-Language).

Y dos capas adicionales:

- **Endurecimiento de instalación de módulos** (Capa 1 controlador + Capa 2 hook `actionBeforeInstallModule`).
- **Aviso por email** al dueño de la tienda + emails configurados, con enlace tokenizado para autorización.

3. Tablas

Tabla	PK	Uso
<code>ps_ecomsec_log</code>	<code>id_log</code>	Registro de los 3 eventos (<code>proceso</code> , <code>login</code> , <code>acceso</code>) y eventos de bloqueo (<code>block_*</code>)
<code>ps_ecomsec_whitelist</code>	<code>id_wl</code>	Lista blanca con <code>cidr</code> , <code>label</code> , <code>active</code> , <code>created_at</code>
<code>ps_ecomsec_geo_cache</code>	<code>ip</code>	Caché 24 h de IP→país por proveedor

DDL completo en `sql/install.php` . Se borra en `sql/uninstall.php` .

4. Configuración (Configuration::*)

Clave	Por defecto
ECOMSEC_EMAILS	PS_SHOP_EMAIL
ECOMSEC_GEO_PROVIDER	ipapi
ECOMSEC_GEO_API_KEY	(vacío)
ECOMSEC_GEO_FAIL_CLOSED	1
ECOMSEC_LOG_RETENTION	90
ECOMSEC_COOKIE_SECRET	random_bytes(32) hex
ECOMSEC_COOKIE_DAYS	7
ECOMSEC_ENABLE_FP	1
ECOMSEC_ENABLE_GEO	1
ECOMSEC_LAST_PURGE	(vacío)
ECOMSEC_CRON_TOKEN	random_bytes(16) hex
GMARTOS_LAST_PING_ecom_secadmin	(timestamp)
GMARTOS_UPDATE_AVAILABLE_ecom_secadmin	0/1

5. Hooks registrados

Hook	Uso
actionDispatcherBefore	Logging temprano de los 3 eventos + purga diaria oportunista
actionAdminControllerInitBefore	Gate completo (geo → módulo-zone → fingerprint → cookie)
displayBackOfficeHeader	Reservado
actionBeforeInstallModule	Capa 2 anti-instalación
actionAdminLoginControllerBefore	Reservado

6. Tabs creados

- AdminEcomSecadmin (parent → CONFIGURE)
- AdminEcomSecadminConfig

- `AdminEcomSecadminLogs`
- `AdminEcomSecadminAccess` (parent dinámico — `AdminParentSecurity` en PS 9 / 8.x ≠ 8.1; `AdminAdvancedParameters` en 1.7.x y 8.1)
- `AdminEcomSecadminDetected`

7. Endpoints públicos

- `/modules/ecom_secadmin/whitelist_add.php` — token HMAC-SHA256 + ip + exp (24 h).
- `/modules/ecom_secadmin/cron.php` — token de purga (no caduca).

8. Compatibilidad multi-versión

Resuelta vía `EcomSecadminCompat` :

- `securityParentClass()` decide tab parent.
- `getRemoteAddr()` con fallback `X-Forwarded-For` .
- `currentEmployeeId/Email()` desde `Context` .
- `currentControllerName()` desde `Tools::getValue('controller')` o `get_class($controller)` .

9. Conexión externa (Gmartos)

`checkGmartosUpdate()` envía POST a `https://modules.gmartos.es/api.php` una vez por semana con `module_name + version + url + email` . Implementado con `file_get_contents` + stream context (sin Guzzle), timeout 3 s, `ignore_errors=true` . Falla en silencio.

10. Mantenimiento

`addnewfeatures()` se ejecuta al entrar en la configuración. Es idempotente: - Re-registra hooks que pudieran haberse perdido. - Reaplica defaults si una clave de configuración fue borrada. - Reinstala tablas si alguna falta. - Envuelve todo en `try{}` silencioso.

11. Seguridad

- HMAC-SHA256 con `hash_equals` (timing-safe) en cookie y token de email.
- `pSQL()` en todo SQL manual.
- Sin `LIMIT 1` añadido a `getRow / getValue` (PS lo añade).
- Sin `session_start` propio (Symfony en 8/9 lo gestiona).
- Estado en `Context::getContext()->cookie` para el flag `acceso` y el fingerprint.

Documento de Desarrollo — Ecom Sec Admin

Para desarrolladores que necesiten integrar, extender o auditar el módulo.

Estructura del módulo

```
ecom_secadmin/  
├─ ecom_secadmin.php          # Clase principal Ecom_Secadmin  
├─ config.xml                 # Manifest  
├─ index.php                  # Redirect anti-listado  
├─ logo.png                   # 64x64  
├─ logo_256.png              # 512x512  
├─ cron.php                   # Endpoint de purga (token)  
├─ whitelist_add.php          # Endpoint de aprobación por email (HMAC)  
├─ classes/  
│   ├─ EcomSecadminCompat.php # Helpers multi-versión PS  
│   ├─ EcomSecadminLog.php     # Log writer/reader/purge/CSV  
│   ├─ EcomSecadminWhitelist.php # CRUD + matcher CIDR (IPv4/IPv6)  
│   ├─ EcomSecadminCookie.php  # Cookie 7d firmada HMAC  
│   ├─ EcomSecadminGeo.php     # IP→país con caché 24h, 4 providers  
│   └─ EcomSecadminFingerprint.php # Hash UA+AcceptLang en PS Cookie  
├─ controllers/admin/  
│   ├─ AdminEcomSecadminConfigController.php  
│   ├─ AdminEcomSecadminLogsController.php  
│   ├─ AdminEcomSecadminAccessController.php  
│   └─ AdminEcomSecadminDetectedController.php  
├─ views/templates/admin/  
│   ├─ config.tpl  
│   ├─ logs.tpl  
│   ├─ access.tpl  
│   └─ detected.tpl  
├─ sql/  
│   ├─ install.php  
│   └─ uninstall.php  
└─ docs/  
    ├─ README.md, INSTALL.md, USER_GUIDE.md, FAQ.md  
    ├─ TECNICO.md, DESARROLLO.md, SECURITY.md  
    └─ CHANGELOG.txt
```

Cómo extender

Añadir un nuevo evento de log

```
require_once _PS_MODULE_DIR_ . 'ecom_secadmin/classes/EcomSecadminLog.php';

EcomSecadminLog::add(array(
    'event_type' => 'mi_evento',
    'controller' => 'AdminMiArea',
    'action'     => 'foo',
    'success'    => 1,
    'extra'      => array('detalle' => 'X'),
));
```

Nota: Si quieres que el visor lo enseñe en el filtro, añade el tipo a `$ecomsec_event_types` en `AdminEcomSecadminLogsController::initContent()`.

Añadir un proveedor de geolocalización

Editar `EcomSecadminGeo::lookupViaProvider()` y añadir un `case`:

```
case 'mi_proveedor':
    return self::providerMiProveedor($ip, $apiKey);
```

Implementar `providerMiProveedor()` siguiendo el patrón de `providerIpInfo()`. Devolver código ISO-2 mayúsculas o `false`.

Añadir nueva configuración persistente

1. Añadir constante `CONF_*` en `Ecom_Secadmin`.
2. Añadirla al array `$defaults` en `installDefaultConfig()`.
3. Añadirla al array `$keys` en `uninstallConfig()`.
4. Añadir el control en `views/templates/admin/config.tpl`.
5. Añadir lectura/escritura en `AdminEcomSecadminConfigController::saveConfig()`.

Hooks personalizados

Si necesitas reaccionar a un evento de bloqueo desde otro módulo:

```
// En tu módulo
public function hookEcomSecadminBlockGeo($params) {
    // $params = ['ip' => ..., 'country' => ..., 'controller' => ...]
}
```

Y desde `Ecom_Secadmin`, antes de bloquear:

```
Hook::exec('ecomSecadminBlockGeo', array('ip' => $ip, 'country' => $country, 'controller' => $controller));
```

(No incluido por defecto. Añádalo si lo necesitas.)

Convenciones de código

- **PHP 7.1+** obligatorio. No usar features 8+ (`match` , `named args`, `readonly`, `enums`).
- **Sin Composer**: nada de Guzzle, Symfony, Dotenv. Funciones nativas.
- `pSQL()` en todo SQL manual.
- **Nunca** `LIMIT 1` con `getRow()` / `getValue()` .
- **Nunca** `session_start()` ni manipular `$_SESSION` (Symfony lo gestiona en 8/9). Usar `Context::getContext()->cookie` .
- **Cabecera AFL-3.0** en todos los archivos (PHP, JS, CSS, TPL, SQL).
- `index.php` **con redirect** en cada subcarpeta.

Testing manual

Caso 1 — IP whitelisted: 1. Login normal → registra `acceso` en log. 2. Acceso a `AdminModules` → permitido.

Caso 2 — IP española no whitelisted: 1. Login normal → permitido. 2. Acceso a `AdminModules` → 403 + email al dueño + log `block_module` .

Caso 3 — IP fuera de España no whitelisted: 1. Login → bloqueado, sesión cerrada, email al dueño + log `block_geo` .

Caso 4 — Cookie expirada: 1. Avanzar el reloj > 7 días. 2. Cualquier request → re-login forzado.

Caso 5 — Fingerprint: 1. Login con Chrome. 2. Cambiar UA via DevTools → log `block_fingerprint` , sesión cerrada.

Integración Gmartos

`checkGmartosUpdate()` en clase principal. Implementación nativa con `file_get_contents` + stream context. Frecuencia 1 ping/semana. Configuration keys con prefijo `GMARTOS*_ecom_secadmin` . Aviso visible en `config.tpl` cuando `$ecomsec_gmartos_update` es true.

Auditoría rápida

```
# 1. Ver eventos recientes
SELECT event_type, ip, country, employee_email, created_at
FROM ps_ecomsec_log
ORDER BY created_at DESC
LIMIT 50;
```

```
# 2. IPs whitelisted activas
SELECT cidr, label, created_at
FROM ps_ecomsec_whitelist
WHERE active = 1;
```

```
# 3. Caché de geo
SELECT ip, country, provider, cached_at
FROM ps_ecomsec_geo_cache
ORDER BY cached_at DESC;
```

Preguntas frecuentes

Estoy fuera de España y no me deja entrar

Es el comportamiento esperado. Pide a alguien con una IP whitelisted que añada la tuya, o utiliza un VPN con salida en España. Si recibiste un email del módulo, pulsa el enlace de aprobación (válido 24 h).

Me he autobloqueado

1. Conecta por **FTP/SSH** y elimina temporalmente el módulo (`/modules/ecom_secadmin/`).
2. Entra al back-office y reinstala el módulo desde una IP de confianza — esa IP se añadirá automáticamente a la whitelist.

He cambiado de IP (mi ISP me cambió la IP doméstica)

Es habitual con IPs domésticas dinámicas. Soluciones:

- Añadir un rango CIDR de tu operador (ej. `83.45.0.0/16`) en lugar de la IP exacta.
- Pulsar el enlace del email cuando intentes entrar y se bloquee.

Ip-api.com es lento o me devuelve error

Cambia el proveedor a **MaxMind GeoLite2 local**: descarga el `.mmdb` desde maxmind.com (gratuito) y colócalo en `/modules/ecom_secadmin/data/GeoLite2-Country.mmdb` .

¿Compatible con 2FA?

Sí, totalmente. Este módulo añade capas independientes (IP, país, fingerprint, cookie). Recomendamos usar ambos.

¿Compatible con CDN / proxy inverso?

PrestaShop ya gestiona `X-Forwarded-For` vía `Tools::getRemoteAddr()` . Asegúrate de que tu proxy (Cloudflare, NGINX, etc.) está configurado para preservar la IP real del cliente.

¿Puedo desactivar el geofencing y dejar sólo la whitelist?

Sí. En **Configuración**, pon "Activar geofencing España" en **No**. Quedan activos: whitelist, cookie de confianza, fingerprint y bloqueo de zona módulos.

¿Cuánto cuesta el módulo en consultas externas?

Una llamada al proveedor de geo **por IP nueva, máximo cada 24 horas**. Para un equipo de 5 personas con IPs estables, suele ser <10 llamadas/mes.

Instalación

Requisitos

- PrestaShop 1.7.8, 8.x o 9.x
- PHP 7.1 o superior
- MySQL 5.6+ / MariaDB 10.x
- Acceso saliente HTTP/HTTPS si usas un proveedor de geolocalización online (ip-api.com, ipapi.co, ipinfo.io). No es necesario si usas MaxMind local.

Pasos

1. Subir la carpeta `ecom_secadmin` a `/modules/` (o instalar el ZIP desde el back-office si vienes desde "Mis módulos > Subir un módulo").
2. Instalar el módulo desde **Módulos > Gestor de módulos > buscar "Sec Admin"**.
3. Al instalar, **la IP del instalador se añade automáticamente a la lista blanca** con etiqueta "Instalador". Esto evita un autobloqueo inmediato.
4. Abrir **Configurar > Sec Admin > Configuración** y revisar: - **Emails de notificación**: destinos extra (el dueño de la tienda recibe siempre). - **Activar geofencing España**: Sí (recomendado). - **Proveedor de geolocalización**: por defecto ip-api.com (sin clave). - **Si la API geo falla**: Bloquear (fail-closed, recomendado).

Primer arranque

Tras instalar:

- Probar el login desde la propia IP del instalador → entra normal.
- Probar desde otra IP no whitelisted → se bloquea (si es fuera de España) o pide login y queda registrado en el log (si es de España).
- En **Configurar > Sec Admin > IPs detectadas** aparecen las IPs vistas; con un clic se añaden a la whitelist.

Cron de purga (opcional)

La purga corre automáticamente una vez al día en el primer acceso al back-office. Si quieres ejecutarla por cron del servidor, copia la URL que aparece en **Configuración > Mantenimiento** (incluye token único) y prográmala diariamente.

```
0 4 * * * curl -s "https://tu-dominio/modules/ecom_secadmin/cron.php?token=XXXXXX"
```

Desinstalación

El módulo elimina sus tablas y configuración al desinstalarse. Si quieres conservar los logs, exporta a CSV antes desde **Sec Admin > Registro de accesos**.

Modelo de seguridad

Matriz de acceso

Origen	Acceso al back-office	Instalar / configurar módulos
IP en whitelist	Sí	Sí
IP en España, no whitelisted	Sí	No (403)
IP fuera de España, no whitelisted	No (sesión cerrada + mail)	No
IP fuera de España, whitelisted	Sí	Sí
Cookie de confianza expirada	No (re-login forzado)	—
Fingerprint mismatch	No (sesión cerrada)	—
Provider geo caído (fail-closed)	No (bloquea)	—

Capas de defensa para instalación de módulos

- Capa 1 — Controlador:** si el controller es `AdminModules*` y la IP no está en whitelist, devuelve 403 antes de procesar el request. Cubre cargas vía interfaz, AJAX y POST directos.
- Capa 2 — Hook `actionBeforeInstallModule`** : si algo se salta la Capa 1 (override de otro módulo, exploit, etc.), el propio install detecta la IP y aborta devolviendo `false`. Si quedó algún rastro parcial, intenta `Module::disable()` sobre el módulo objetivo.

CLI (composer/console) está exento de la Capa 2 — útil para pipelines de despliegue. Si quieres bloquearlo también, edita `hookActionBeforeInstallModule` y elimina la rama `PHP_SAPI === 'cli'`.

Geofencing

- API de geo se llama **una vez por IP cada 24 horas**; el resto se sirve desde caché local (`ecomsec_geo_cache`).
- IPs privadas / loopback no se consultan (se consideran "desconocidas", no se enforcan en LAN).
- Comportamiento en fallo configurable: fail-closed (recomendado) o fail-open.

Cookie de confianza

- Estructura: `id_employee . ip . expires . HMAC-SHA256(secret)`
- Flags: `HttpOnly + Secure + SameSite=Strict`
- Vida: 7 días por defecto.

- Vinculada al `id_employee` y a la IP de origen del login. Si el atacante copia la cookie a otra máquina, la IP no coincide y la sesión se cierra.
- Secret: generado con `random_bytes(32)` al instalar, almacenado en `Configuration`.

Token de aprobación por email

- Estructura: `ip . exp` firmado con HMAC-SHA256 (mismo secret que la cookie).
- Vida: **24 horas**.
- Validación con `hash_equals` (timing-safe).
- Idempotente: si la IP ya está en whitelist al pulsar el enlace, no se duplica.

Logs

- Tabla `ecomsec_log`: id, tipo de evento, IP, país, empleado, controlador, acción, módulo, UA, Accept-Language, success, extra (JSON), created_at.
- Retención por defecto **90 días**, configurable.
- Purga diaria automática + endpoint cron protegido por token.

Lo que el módulo NO hace (consciente)

- No reemplaza al **2FA**: complementa.
- No bloquea por intentos fallidos (rate-limit). Es candidato para una fase futura.
- No detecta VPN/proxy comerciales más allá de lo que el provider geo declare.
- No re-escribe URLs ni cifra el tráfico (eso lo hace HTTPS / proxy).